

Design and Implementation of a Web-Based End-to-End Encrypted Secure Storage Service

Università di Bologna – Cybersecurity (Colajanni/Russi)

Who of you uses cloud storage regularly?
(Dropbox, Google Drive, OneDrive, etc.)

Who of you stores sensitive data in the cloud?
(personal photos, financial data, identity documents, etc.)

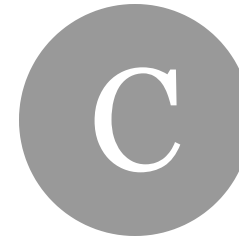
How long does it take cybercriminals to exploit your data once it's for sale on the dark web?^[1]



1 hour



6 hours



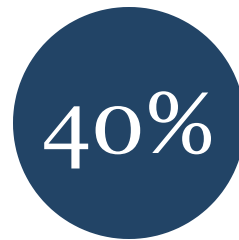
12 hours

[1] <https://ksltv.com/468945/how-quickly-hackers-access-use-your-personal-data-following-a-data-breach/>

How long does it take cybercriminals to exploit your data once it's for sale on the dark web?^[1]



1 hour



6 hours



12 hours

[1] <https://ksltv.com/468945/how-quickly-hackers-access-use-your-personal-data-following-a-data-breach/>

Motivation

- **Risk = Probability × Damage**
- Probably **low risk** with big companies, right?^{2,3}
- **Increasing risk of becoming a victim** of cybercriminals⁴
- Potentially **huge** personal **damage**
 - Identity theft & fraud
 - Financial theft
 - Reputational damage
 - ...

[2] <https://arstechnica.com/information-technology/2016/08/dropbox-hackers-stole-email-addresses-hashed-passwords-68m-accounts/>

[3] <https://www.theguardian.com/technology/2014/sep/01/naked-celebrity-hack-icloud-backup-jennifer-lawrence/>

[4] <https://www.statista.com/markets/424/topic/1065/cyber-crime-security/>

Data is the new Oil

- Rise of **data-driven business models**
- **Data** is the **building block** for an **AI-driven world**
- **Lack of transparency** with data in the **cloud**
- **Personal data** may be used for **AI training**
- *“If you don't **pay** for the product, you **are** the product”* – Tristan Harris



“We believe that privacy is a fundamental human right.” [5]

– Tim Cook

[5] https://x.com/tim_cook/status/1055035539915718656

Application Scope

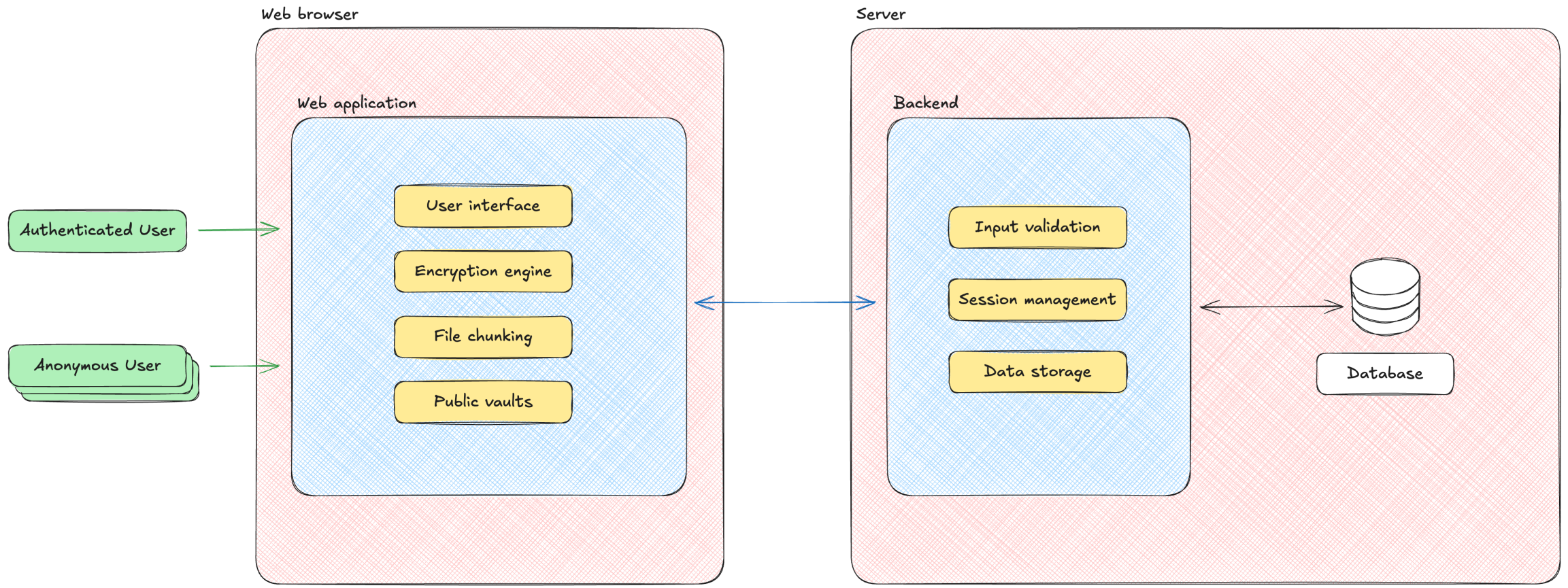
- **Register** a new user
- **Log into** an existing account
- **Upload** encrypted files
- **List** stored files
- **Download** and decrypt files
- **Delete** files
- ***Public vaults*** for collaboration
- $\Rightarrow$ Keep attack surfaces **minimal**

Cryptographic Design

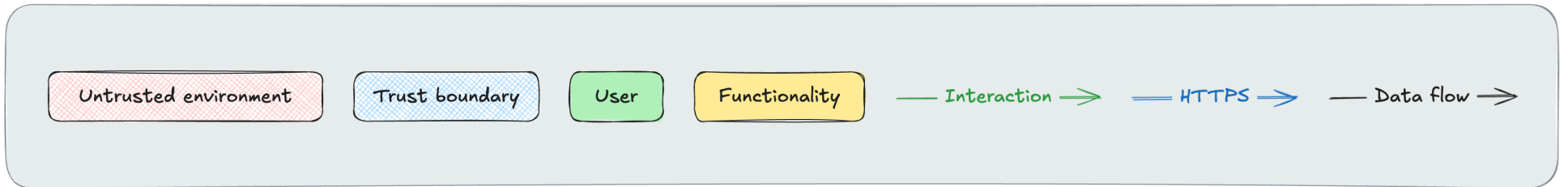
- Based on an **audited** and **production-ready** design by MEGA^[6]
- **Updated** to use more **modern encryption** algorithms
- **Early adoption** of **preventive** and **defensive strategies** and **technologies**
- **Goal: Mitigate** the **risk** of unauthorized access to **private data**
- *"A cryptosystem should remain secure even if everything about the system, except the key, is public knowledge."* - Auguste Kerckhoff
- *"The security of a cryptographic system should rely on the secrecy of the key, not the secrecy of the algorithm."* - Whitfield Diffie

[6] <https://mega.nz/SecurityWhitepaper.pdf>

System Architecture



Legend



Implementation

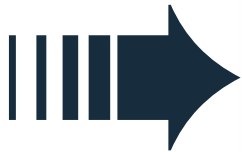
- **TypeScript** for type-safety
- **SvelteKit**^[7] for both frontend and backend
- **SQLite** for quick prototyping
- **Audited** library `@noble`^[8] for modern encryption
- **FastCDC**^[9] for content-defined chunking

[7] <https://svelte.dev/>

[8] <https://paulmillr.com/noble/>

[9] <https://www.usenix.org/system/files/conference/atc16/atc16-paper-xia.pdf>

LIVE Presentation



Threat Analysis

1. Analyze and identify vulnerabilities and threats							2. Estimate and evaluate risk			
ID	System Overview/Context View	Vulnerability	STRIDE Category	Threat	Asset	Impact	CVSS Base Score	CVSS Vector String	CVSS Rating	Risk
1	Operating System	Outdated OS vulnerabilities	Spoofing, Tampering, Elevation of Privilege	Unauthorized access via unpatched OS exploits	System & Data	Potential full system compromise	9.8	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Critical	High
2	npm Ecosystem Dependencies	Malicious package injection	Tampering, Information Disclosure	Third-party dependency compromise	Application Code	Unauthorized system access	9.8	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Critical	High
3	API Endpoints	Excessive API permissions	Elevation of Privilege	Users might perform unauthorized actions via misconfigured API	Application Logic	Unauthorized modification of system state	8.3	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L	High	High
4	Browser-Based Cryptography	Potential flaws in cryptographic library	Tampering	Weaknesses in cryptographic operations leading to exposure	Encrypted Data	Data compromise due to weak cryptographic implementation	8.2	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	High	High
5	User Authentication	Weak password policy	Elevation of Privilege	Users may set weak passwords, increasing brute-force success	User Accounts	Unauthorized access to user data	8.2	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	High	High
6	Authentication Mechanism	No brute-force protection	Elevation of Privilege	Credential stuffing attacks	User Accounts	Unauthorized access to user accounts	7.5	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	High	High
7	Cryptographic Key Management	No key rotation strategy	Tampering	Compromised encryption keys remaining valid indefinitely	Encryption Keys	Long-term exposure of encrypted data	8.2	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	High	High
8	Web Storage Service	Master key stored in browser storage	Information Disclosure, Tampering	Key exposure through malicious scripts	Encryption Keys	Unauthorized decryption of files	9.8	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	Critical	High
9	Public Vaults	Malicious file uploads	Information Disclosure, Spoofing	Attackers may upload malicious files leading to compromise	User Files	Execution of malicious files or phishing attempts	8.3	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:L	High	High
10	Public Vault Authentication	Risk of replay attacks	Spoofing	Attackers replay authentication tokens to gain unauthorized access	Vault Access	Unauthorized access to uploaded files	8.2	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	High	High

3. Control security risk			4. Assess risk after mitigation			
ID	Security Risk Mitigation Specification	Verification of Security Risk Controls	CVSS Base Score	CVSS Vector String	CVSS Rating	Risk
1	Regular OS updates, vulnerability scanning	Check patch logs and vulnerability scan reports	6.3	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L	Medium	Reduced
2	Perform manual audits of critical dependencies, pin versions	Verify SBOM and pinned versions	5.4	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N	Medium	Reduced
3	Implement least privilege access control, review API permissions	Check role-based access and run permission tests	4.2	AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N	Medium	Reduced
4	Rely on well-audited libraries, validate cryptographic integrity	Check cryptographic audits and library integrity	4.3	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N	Medium	Reduced
5	Enforce strong password policies, require MFA	Check MFA logs and validate password complexity settings	3.7	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N	Low	Reduced
6	Implement rate limiting, CAPTCHA, account lockout	Inspect rate-limit triggers and lockout logs	3.7	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N	Low	Reduced
7	Implement periodic key rotation with re-encryption	Check key rotation logs and verify re-encryption process	4.3	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N	Medium	Reduced
8	Use secure enclave or hardware security module for key storage	Check hardware key management logs and local storage use	5.4	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N	Medium	Reduced
9	File type validation, antivirus scanning, user confirmations before execution	Check file scanning logs and file type validations	5.4	AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N	Medium	Reduced
10	Implement nonce-based authentication challenges	Verify replay detection and time-limited token settings	3.7	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N	Low	Reduced

Limitations

- **No security audits** (yet)
- **Single root folder**
- **Single** SQLite database for **all** data
- **Public vault links** do not **expire**
- **No automatic clean-up** of **unreferenced chunks**

Future Work

- **Audits** by third-party professionals
- Better **server-side** measures (e.g., rate limiting)
- Automatic **key rotation** mechanisms
- Better **user session management**
- **Expiring** public vault **links**
- **File sharing** via public links
- Automatic **clean-up** of **unreferenced chunks**

Conclusion

- Relatively **little effort** to achieve **end-to-end encrypted cloud storage**
- **Audited cryptographic design** used in production
- Based on a modern, **audited encryption library**
- **Threat analysis** to determine the impact of **risks** and **vulnerabilities**
- **But:** software will **always** have **bugs** and **security issues**
- $\Rightarrow$ **Always stay sceptical**

Thank you for your attention